Zero Trust Architecture — Conditional Access Baseline & Rollout — Government (GCC High)

Implementation Solution Guide

Version 1.0.0 · 2026-07-10

Contents

Executive Summary — Zero Trust Architecture: Conditional Access Baseline & Rollout 5
What you get . . . 5
What this delivers . . . 5
The standard deployment model . . . 6
Outcome . . . 6
1. Solution Overview — Zero Trust Architecture: Conditional Access Baseline & Rollout 6
Zero Trust and why identity is the control plane . . . 6
The Conditional Access model — signals, conditions, controls . . . 7
Personas — designing the baseline by who the user is . . . 7
Report-only mode and the What-If tool — validate before you enforce . . . 7
Break-glass and exclusions — the anti-lockout discipline . . . 8
Licensing note (be honest) — and GCC High/DoD parity . . . 8
What you can control . . . 8
Benefits . . . 8
Limitations (be honest with buyers) . . . 9
The standard deployment model . . . 9
Authentication and connections used (GCC High / Azure Government) . . . 9
2. Requirements Guide — Zero Trust Architecture: Conditional Access Baseline & Rollout 9
2.1 Entra ID licensing for Conditional Access . . . 10
2.2 Administrative roles . . . 10
2.3 Persona definition and group mapping . . . 10
2.4 Pilot ring . . . 10
2.5 Break-glass accounts and exclusion group . . . 11
2.6 Device management (for device-based controls) . . . 11
2.7 Legacy authentication assessment . . . 11
2.8 Microsoft Graph PowerShell SDK . . . 11
2.9 Sensitive-apps and privileged-users decision . . . 11
Checklist . . . 12
Global Requirements — Entra ID Solutions (category-level) 12
G1. Microsoft Entra ID tenant . . . 12
G2. Entra ID licensing (P1, P2 where noted) . . . 12
G3. Administrative roles . . . 12
G4. Break-glass (emergency access) accounts . . . 12
G5. Healthy on-premises Active Directory . . . 13
G6. An Entra Connect host server . . . 13

G7. UPN / domain hygiene . . . 13
G8. Network access to Microsoft cloud endpoints . . . 13
GCC High Parity Notes — Zero Trust Conditional Access Baseline & Rollout 13
National cloud endpoints . . . 14
Feature-parity considerations . . . 14
Compliance & data-residency context (why GCC High — and the Zero Trust mandate) . . . 15
DoD (IL5) note . . . 16
3. Implementation Guide — Zero Trust Architecture: Conditional Access Baseline & Rollout 16
Step 1 — Create the persona, exclusion, and pilot groups . . . 18
Step 2 — Assess the current state (baseline) . . . 18
Step 3 — Build the baseline in report-only . . . 18
Step 4 — Validate every policy with What-If and report-only data . . . 19
Step 5 — Pilot enforcement on the pilot ring . . . 19
Step 6 — Enforce wave by wave . . . 19
Step 7 — Operate and review . . . 20
5. Testing Guide — Zero Trust Architecture: Conditional Access Baseline & Rollout 20
Test 1 — Baseline exists and is report-only . . . 20
Test 2 — Break-glass is excluded from every policy . . . 21
Test 3 — What-If matches the persona design . . . 21
Test 4 — Report-only impact is clean . . . 21
Test 5 — MFA is required where enforced . . . 21
Test 6 — Phishing-resistant MFA required for admins . . . 21
Test 7 — Device control enforced . . . 21
Test 8 — Legacy authentication blocked . . . 21
Test 9 — Risk policies fire (P2 only) . . . 21
Test 10 — Rollback works . . . 22
Pass/fail gate . . . 22
6. Troubleshooting Guide — Zero Trust Architecture: Conditional Access Baseline & Rollout 22
A. Discovery / validation errors . . . 22
B. A policy locked users out (or would have) . . . 22
C. Break-glass exclusion keeps disappearing . . . 23
D. Report-only shows nothing / What-If disagrees . . . 23
E. Risk policies (CA004/CA005) not available or not firing . . . 23
F. Device control (CA003) blocks compliant users . . . 24
G. Legacy-auth block (CA007) broke an app . . . 24
H. Phishing-resistant strength (CA002) rejects everyone . . . 24

I. Diagnostics quick reference . . . 24
J. When to escalate . . . 24
7. Best Practices — Zero Trust Architecture: Conditional Access Baseline & Rollout 25
Where to go next . . . 26
8. Deliverables Summary — Zero Trust Architecture: Conditional Access Baseline & Rollout 26
Documentation . . . 26
PowerShell scripts . . . 27
What the buyer receives . . . 27
Outcome . . . 28
Appendix A — PowerShell Scripts 29

Executive Summary — Zero Trust Architecture: Conditional Access Baseline & Rollout

White-label · Entra ID Solutions · Government (GCC High) edition

This is the **Government (GCC High)** edition for US public-sector and defense-industrial-base tenants operating in **Microsoft Entra for GCC High / Azure Government**. It mirrors the commercial method exactly, adapted for the sovereign cloud — the Azure Government portal (`portal.azure.us` → Microsoft Entra ID), Azure Government sign-in (`login.microsoftonline.us`), the GCC High Graph host (`graph.microsoft.us`; DoD/IL5 `dod-graph.microsoft.us`), and PowerShell targeting the US Gov cloud (`Connect-MgGraph -Environment USGov`). It is the direct answer to the **federal Zero Trust mandate — OMB M-22-09** (phishing-resistant MFA, Zero Trust architecture aligned to the CISA Maturity Model and NIST SP 800-207) and to **CMMC 2.0 / NIST SP 800-171** access-control expectations for the DIB. Because parity in GCC High/DoD can lag commercial — notably risk-based CA (Entra ID P2 / Identity Protection) — every such capability is flagged to **verify against current Microsoft Government documentation** (see the included `gcc-high-parity-notes.md`).

Zero Trust starts at identity, and in Microsoft Entra the engine that enforces it is Conditional Access (CA). Every sign-in is evaluated against policy — who you are, what device you are on, how risky the sign-in looks — and access is granted only when the conditions are met. Done well, CA is the strongest control you have. Done carelessly, a single overbroad policy locks the whole tenant out of its own directory. The difference is method: personas, report-only validation, break-glass protection, and a staged rollout.

This is a complete, deploy-it-today package for designing and rolling out a Conditional Access baseline in Microsoft Entra, written for an administrator with no prior CA-architecture experience. It gives you a repeatable way to define access personas, build a numbered set of baseline policies (MFA, compliant/hybrid device, risk-based, session controls, block legacy auth), validate every one of them in **report-only** with the What-If tool before it can block anyone, and enforce them in waves with break-glass accounts and a rollback path.

What you get

• A plain-language Solution Overview of the Conditional Access model — signals, conditions, grant and session controls, authentication strengths, report-only mode, and the persona approach to Zero Trust.

• A Requirements Guide with verify / implement-if-missing for every solution-specific prerequisite.

• An Implementation Guide of precise, click-by-click Entra steps that builds a named, numbered baseline and rolls it out report-only -> validate -> enforce, wave by wave.

• Five PowerShell scripts for CA and persona discovery, report-only impact reporting, baseline policy creation (preview by default), persona-group targeting, and a validation check.

• Testing and Troubleshooting guides for a confident, staged rollout.

What this delivers

A production Zero Trust Conditional Access baseline — personas defined for admins, internal staff, external/guest users, and service accounts; a numbered set of baseline policies enforcing MFA, device

compliance, risk-based access, and session controls; every policy proven in report-only and What-If before enforcement; break-glass accounts excluded throughout; and a wave-based rollout with a one-click rollback — deployed without ever locking out the tenant.

The standard deployment model

Assess -> Configure -> Pilot -> Validate -> Expand.

Outcome

Least-privilege, Zero Trust access enforced at the identity plane — a clean, numbered Conditional Access baseline rolled out safely in waves, validated in report-only first, with break-glass and rollback so there are no lock-outs.

> *Some controls in the baseline require Microsoft Entra ID P2 (sign-in and user risk conditions) or Intune device compliance. Where a policy depends on a specific license or product this package flags it — *verify current availability in your tenant* and substitute an equivalent control if you are P1-only.*

1. Solution Overview — Zero Trust Architecture: Conditional Access Baseline & Rollout

> ***Government (GCC High) edition.*** *This is the US Government national-cloud edition for public-sector and defense-industrial-base (DIB) tenants running in **Microsoft Entra for GCC High / Azure Government**. It mirrors the commercial method exactly, adapted for the sovereign cloud: the Entra/Azure Government admin experience (`portal.azure.us` → Microsoft Entra ID — *verify the current GCC High Entra admin-center URL for your tenant*), Azure Government sign-in (`login.microsoftonline.us`), the GCC High Graph host (`graph.microsoft.us`; DoD/IL5 uses `dod-graph.microsoft.us`), and PowerShell targeting the US Gov cloud (`Connect-MgGraph -Environment USGov`). Feature parity in GCC High/DoD can **lag commercial** — notably **risk-based Conditional Access (sign-in/user risk via Entra ID P2 / Identity Protection)**, authentication strengths, and some device controls — so those must be **verified against current Microsoft Government documentation** (see `gcc-high-parity-notes.md`).*
>
> ***Why this matters for the public sector (the driver).*** *Federal Zero Trust is a **mandate**, not an aspiration: OMB Memorandum **M-22-09** ("Moving the U.S. Government Toward Zero Trust Cybersecurity Principles") directs agencies to a Zero Trust architecture with **phishing-resistant MFA** for staff, contractors, and partners as a core requirement, aligned to the **CISA Zero Trust Maturity Model** and **NIST SP 800-207**. For the defense-industrial base, **CMMC 2.0 / NIST SP 800-171** carry parallel access-control and MFA expectations. A Conditional Access baseline — enforcing MFA, phishing-resistant MFA for privileged users, device compliance, and blocked legacy authentication — is exactly how those mandates are operationalized at the identity plane in GCC High.*

Zero Trust and why identity is the control plane

Zero Trust replaces the old "trusted internal network" with a simple rule: never trust, always verify. Every access request is authenticated, authorized, and evaluated against policy, regardless of where it comes from. In a Microsoft cloud estate the place that rule is actually enforced is the identity plane — Microsoft

Entra — and the mechanism is Conditional Access. If a request cannot satisfy the CA policy for the persona and resource it is reaching, it does not get in. That is why a Conditional Access baseline is the foundation of a Zero Trust program.

The Conditional Access model — signals, conditions, controls

A Conditional Access policy is an if-then statement. The **if** is a set of **assignments and conditions**: which users/groups (and exclusions), which target resources (cloud apps or user actions), and conditions such as device platform, location, client app, sign-in risk, and user risk. The **then** is a set of **controls**:

- **Grant controls** — allow only if the sign-in meets a requirement: require MFA, require a specific authentication strength (for example phishing-resistant MFA), require a compliant device, require a hybrid Entra-joined device, require app protection policy, or block access entirely. Multiple controls can be combined with AND / OR.
- **Session controls** — shape the session once granted: sign-in frequency, persistent browser session, app-enforced restrictions (for example web-only, no download for guests), and Conditional Access app control via Defender for Cloud Apps.

Because a policy can target "all users" and "all cloud apps," it is powerful enough to lock everyone — including admins — out of the tenant in one save. The whole method below exists to prevent that.

Personas — designing the baseline by who the user is

The clean way to build a baseline is by **persona**, not one giant policy. Each persona gets policies appropriate to its risk:

- **Admins** — the highest-value accounts. Require phishing-resistant MFA, tighter session controls (sign-in frequency, no persistent browser), and no legacy authentication.
- **Internal staff** — the workforce. Require MFA and a compliant or hybrid-joined device; block legacy auth.
- **External / guest users** — require MFA and app-enforced session restrictions; limit what they can do and download.
- **Service accounts / workload identities** — non-interactive accounts that break under interactive MFA. They are scoped out of interactive policies and, where licensed, governed by dedicated workload-identity Conditional Access instead; each one is documented and exception-tracked.

Personas map to security groups, and policies target those groups — so the baseline is legible, auditable, and rolled out group by group.

Report-only mode and the What-If tool — validate before you enforce

Two Entra features make a safe rollout possible:

- **Report-only mode** — a policy set to `Report-only` is fully evaluated on every sign-in and logged ("would have granted / would have blocked / would have required MFA") **without actually enforcing** anything. You read the impact in `Conditional Access -> Insights and reporting` (a `Log`

Analytics workbook) and confirm the policy does what you intend, and does not catch break-glass or service accounts, before you turn it on.

- **What-If** — a simulator (`Conditional Access -> What If`) where you pick a user, app, device state, and conditions and see exactly which policies would apply and which controls would fire — without any real sign-in. It is how you sanity-check a policy against each persona before enabling it.

The rule for the whole baseline: **every policy is created in report-only, validated with report-only data and What-If, and only then enforced** — in waves.

Break-glass and exclusions — the anti-lockout discipline

Two cloud-only emergency access (break-glass) accounts are **excluded from every policy** so a bad policy can never lock all admins out (global requirement G4). Beyond break-glass, exclusions are kept deliberate and minimal — each exclusion is a documented exception (a service account, a specific legacy app, a temporary carve-out), not a convenience, because every exclusion is a hole in the baseline.

Licensing note (be honest) — and GCC High/DoD parity

- MFA, device compliance, and session controls are available with Entra ID P1.
- **Sign-in risk and user risk conditions** (Identity Protection) require **Entra ID P2** — *verify your licensing*. If you are P1-only, substitute equivalent non-risk policies (for example require compliant device + MFA everywhere) and note the gap.
- **In GCC High/DoD, Identity Protection (risk-based CA, `CA004`/`CA005`), authentication-strength definitions, and some device controls may lag commercial or differ in availability. **Do not assume a risk-based or preview capability is present in the sovereign cloud —** verify each against current Microsoft Government documentation** for your specific cloud (GCC High vs DoD/IL5) before you design around it. Phishing-resistant MFA (FIDO2/passkey) for admins — the M-22-09 requirement — is the non-risk control to lead with regardless of P2 availability.
- **Require compliant device** depends on **Intune** device compliance; **require hybrid Entra-joined device** depends on Entra hybrid join. *Verify these are in place* or use the control the tenant supports.

What you can control

- Personas and their group mappings.
- A numbered baseline: MFA, phishing-resistant MFA for admins, compliant/hybrid device, sign-in and user risk (P2), app-enforced restrictions for guests, block legacy auth, and admin session controls.
- The rollout state of each policy: report-only -> enforce, wave by wave.
- Exclusions and break-glass — deliberate and documented.

Benefits

- Security — least-privilege access enforced at every sign-in; legacy auth and un-managed devices shut out; risk-based step-up where licensed.

• Safety — report-only + What-If + break-glass mean the baseline is deployed without lock-outs.

• Legibility — a numbered, persona-based set of policies anyone can read and audit, not a tangle.

• Repeatability — a wave pattern you re-run for each group and each new policy.

Limitations (be honest with buyers)

• Risk-based policies need Entra ID P2; some device controls need Intune / hybrid join — *verify licensing* and substitute where needed.

• A CA baseline governs access; it is not a full Zero Trust program on its own (device management, data protection, and network controls are separate, adjacent solutions).

• Which apps are "sensitive," which staff are "privileged," and how strict guest access must be are business/security decisions the customer owns — the guide provides the controls, not the determinations.

The standard deployment model

> *Assess current CA policies and personas -> Configure the numbered baseline in report-only, scoped to persona groups, with break-glass excluded -> Pilot on a pilot ring and validate with report-only data + What-If -> Validate against pass/fail gates -> Expand by enforcing wave by wave with rollback ready. repeatable pattern: Assess -> Configure -> Pilot -> Validate -> Expand.*

Authentication and connections used (GCC High / Azure Government)

• Microsoft Entra admin center for GCC High — the Azure Government portal (`https://portal.azure.us` →

Microsoft Entra ID) for Conditional Access policies, report-only insights, and What-If. *Verify the current GCC High Entra admin-center URL for your tenant.* Sign-in is via `login.microsoftonline.us`.

• Microsoft Graph PowerShell SDK connected to the US Gov cloud (`Connect-MgGraph -Environment USGov`;

Graph host `graph.microsoft.us`, DoD/IL5 `dod-graph.microsoft.us`) for read-only discovery/validation/reporting and the safe, preview-by-default baseline-policy creation (scopes named in each script header).

2. Requirements Guide — Zero Trust Architecture: Conditional Access Baseline & Rollout

Verify every requirement before configuring. Each entry: Description / Why / Verify / Implement-if-missing. Category-wide prerequisites are in `global-requirements-entra-id-solutions.md` (tenant, licensing, admin roles, break-glass accounts, network access) — this guide adds only what is specific to a Conditional Access baseline.

> ***Government (GCC High) edition.*** *All portal verification uses the GCC High / Azure Government experience: the Azure Government portal (`portal.azure.us` → Microsoft Entra ID — *verify the current GCC High Entra admin-center URL*), the GCC High Microsoft 365 admin center*

*(`portal.office365.us` — *verify current URL*), sign-in `login.microsoftonline.us`, Graph host `graph.microsoft.us` (DoD/IL5 `dod-graph.microsoft.us`), and scripts connecting with `Connect-MgGraph -Environment USGov`. **Parity can lag commercial** — risk-based CA (Entra ID P2 / Identity Protection, `CA004`/`CA005`), authentication strengths, and some device controls **may be delayed, unavailable, or different** in GCC High/DoD. **Verify each against current Microsoft Government documentation** for your cloud (GCC High vs DoD/IL5) before designing around it. See `gcc-high-parity-notes.md`.*

2.1 Entra ID licensing for Conditional Access

Description: Microsoft Entra ID P1 for Conditional Access itself; Entra ID P2 additionally for the risk-based conditions (sign-in risk, user risk from Identity Protection). Why: CA is a P1 feature; the risk policies in the baseline (`CA004`, `CA005`) read Identity Protection risk signals that require P2. *Verify current availability* — bundles change, and in **GCC High/DoD** Identity Protection / risk-based CA may lag or differ from commercial; **verify against current Microsoft Government documentation** before you rely on `CA004`/`CA005`. Verify: GCC High Microsoft 365 admin center (`portal.office365.us` — *verify current URL*) -> `Billing -> Licenses`; confirm Entra ID P1 (and P2 if you want risk policies). Government SKUs (e.g. GCC High G3/G5) carry the equivalent P1/P2 plans — confirm the plan is the Government variant. Implement: Assign M365 E3/E5, EMS E3/E5, or standalone P1/P2. If P1-only, omit `CA004`/`CA005` and compensate with compliant-device + MFA everywhere (note the gap).

2.2 Administrative roles

Description: `Conditional Access Administrator` (or `Security Administrator`) to create and manage the policies; `Global Reader` / `Security Reader` for read-only discovery; reserve `Global Administrator` for tenant-wide first-time changes. Why: Creating and enforcing CA policies is a high-privilege action; least privilege keeps the blast radius small. Verify: Entra -> `Roles and administrators`; confirm the operator holds `Conditional Access Administrator`. Implement: Assign the role (ideally PIM-eligible); use a `Security Reader` for the discovery scripts.

2.3 Persona definition and group mapping

Description: A documented set of access personas — admins, internal staff, external/guest, service accounts — each mapped to a security group: `CA Persona - Admins - Steady`, `CA Persona - Internals - Steady`, `CA Persona - Externals-Guests - Steady`, `CA Persona - Service-Accounts - Steady`. Why: The baseline is built by persona; policies target these groups so the design is legible, auditable, and rolled out group by group. Verify: The groups exist with correct membership; run `ENTZTCAG-Set-ScopeTargeting.ps1` to create/preview. Implement: Create the groups with `ENTZTCAG-Set-ScopeTargeting.ps1` (see Implementation Step 1); use dynamic membership where a rule fits (for example guests = `userType eq 'Guest'`).

2.4 Pilot ring

Description: A pilot ring group `CA Pilot Ring - Pilot - Pilot` of representative users across personas, used to validate enforcement before a wave. Why: Every enforce step is proven on a small ring first; the pilot ring is the gate between report-only and wave enforcement. Verify: The group exists with representative members; run `ENTZTCAG-Set-ScopeTargeting.ps1`. Implement: Create it with `ENTZTCAG-Set-ScopeTargeting.ps1`.

2.5 Break-glass accounts and exclusion group

Description: Two cloud-only emergency access accounts (global requirement G4) and a dedicated exclusion group `CA Exclusion - Break-Glass - Steady` containing them, excluded from **every** policy. Why: A misconfigured policy could otherwise lock out all admins; break-glass excluded from every policy is the anti-lockout guarantee. Verify: Entra -> `Users`; two cloud-only `@onmicrosoft.com` admins exist and are members of `CA Exclusion - Break-Glass - Steady`, which is excluded from every policy. Implement: Create the accounts and the exclusion group; add the group as an exclusion on every policy; store credentials securely and monitor their sign-ins.

2.6 Device management (for device-based controls)

Description: Intune device compliance (for `Require compliant device`) and/or Entra hybrid join (for `Require hybrid Entra-joined device`). Why: The device grant controls in the baseline only work if devices can actually report compliance or be hybrid-joined. *Verify current availability in your tenant.* Verify: Entra -> `Devices` shows compliant / hybrid-joined devices; Intune compliance policies exist. Implement: Stand up Intune compliance or Entra hybrid join first (adjacent solutions), or use the device control the tenant supports and note the gap.

2.7 Legacy authentication assessment

Description: Knowledge of which apps/clients in the tenant still use legacy (basic) authentication, which cannot do MFA and must be blocked. Why: The baseline blocks legacy auth (`CA007`); enforcing it blindly can break a legacy line-of- business app or mail client. Verify: Run `ENTZTCAG-Discovery.ps1` (legacy-auth section) and review sign-in logs filtered to legacy client apps. Implement: Identify legacy-auth users/apps, migrate them to modern auth, then block legacy in waves.

2.8 Microsoft Graph PowerShell SDK

Description: The Microsoft Graph PowerShell SDK on the operator workstation, consented to the scopes the scripts use. Why: Discovery, reporting, validation, and the safe baseline creation read and (only when applied) write Conditional Access policies and read sign-in logs through Microsoft Graph. Verify: `Get-Module -ListAvailable Microsoft.Graph.Authentication` returns a version; a test `Connect-MgGraph` succeeds. Implement: `Install-Module Microsoft.Graph -Scope CurrentUser`; scripts request least privilege (`Policy.Read.All`, `AuditLog.Read.All`, `Directory.Read.All`, and — only for baseline creation — `Policy.ReadWrite.ConditionalAccess`).

2.9 Sensitive-apps and privileged-users decision

Description: A documented list of which applications are "sensitive" and which users/roles are "privileged." Why: Several baseline policies scope to these; the classification is a business/security decision, not a technical default. Verify: Security/business owners have named the privileged roles and sensitive apps. Implement: Capture the list; it drives the admin and sensitive-app policy scopes. Customer compliance/security owns the determination.

Checklist

- Entra ID P1 confirmed (P2 if using risk policies `CA004`/`CA005`)
- `Conditional Access Administrator` assigned; `Security Reader` for discovery
- Persona groups created — `ENTZTCAG-Set-ScopeTargeting.ps1`
- Pilot ring group created
- Break-glass accounts + `CA Exclusion - Break-Glass - Steady` group created and excluded everywhere
- Device compliance / hybrid join verified (for device controls)
- Legacy-auth assessment complete — `ENTZTCAG-Discovery.ps1`
- Microsoft Graph PowerShell SDK installed and consented
- Sensitive-apps and privileged-users list documented by the business

Global Requirements — Entra ID Solutions (category-level)

These requirements apply to every solution in the Entra ID Solutions category. They are published once at the category level so individual listings stay small. Confirm these before deploying any identity solution. Each entry: Description / Why / Verify / Implement-if-missing.

> *The identity plane is high risk. A mistake here breaks sign-in for everyone, so every change is staged and a break-glass account is kept ready before you touch anything.*

G1. Microsoft Entra ID tenant

Description: An active Microsoft Entra ID tenant. Why: It is the cloud identity backbone every other identity service builds on. Verify: Sign in to `https://entra.microsoft.com` as an administrator. Implement: Create a Microsoft 365 or Azure subscription, which provisions a tenant.

G2. Entra ID licensing (P1, P2 where noted)

Description: Microsoft Entra ID P1 (or P2 for risk-based and PIM features). Why: Hybrid features such as seamless sign-in, password writeback, and Conditional Access require P1+. Verify: M365 admin center -> `Billing -> Licenses`; confirm Entra ID P1/P2 (often bundled in M365 E3/E5 or EMS). Implement: Assign M365 E3/E5, EMS E3/E5, or standalone Entra ID P1/P2.

G3. Administrative roles

Description: Hybrid Identity Administrator and Global Administrator for the operator. Why: Configuring directory synchronization and authentication methods needs these elevated roles. Verify: Entra -> `Roles and administrators`; confirm `Hybrid Identity Administrator` (and a Global Administrator for the one-time first-sync consent). Implement: Assign `Hybrid Identity Administrator`; reserve `Global Administrator` for tenant-wide and first-sync changes.

G4. Break-glass (emergency access) accounts

Description: At least two cloud-only emergency access accounts, excluded from Conditional Access and MFA-broad policies. Why: If sync, federation, or an auth-method change locks out admins, break-glass accounts get you back in. Verify: Entra -> `Users`; confirm two cloud-only accounts (`@onmicrosoft.com`) with strong stored credentials and documented use. Implement: Create two cloud-only Global Administrator accounts; exclude them from policies; store credentials securely and monitor sign-ins.

G5. Healthy on-premises Active Directory

Description: A functional AD forest/domain with healthy replication and DNS. Why: Synchronization reads from AD; replication or DNS faults corrupt or stall the sync. Verify: Run `dcdiag` and `repadmin /replsummary` on a domain controller with no errors; run `HYBID-Discovery.ps1`. Implement: Resolve AD replication, DNS, and time-sync issues before synchronizing.

G6. An Entra Connect host server

Description: A domain-joined Windows Server (2016+), patched, for Microsoft Entra Connect Sync (or a lightweight host with the Cloud Sync agent). Why: Connect Sync runs as a service on this host and must reach both AD and Entra ID. Verify: A supported, domain-joined server with TLS 1.2, .NET, and PowerShell available; run `HYBID-Discovery.ps1`. Implement: Provision a dedicated server (not a domain controller for production), patch it, and enable TLS 1.2.

G7. UPN / domain hygiene

Description: User principal names use a public, verified, routable domain (not `.local`). Why: A non-routable UPN suffix produces sign-in problems and `onmicrosoft.com` fallbacks in the cloud. Verify: Entra -> `Identity -> Settings -> Domain names` shows the public domain Verified; AD UPN suffixes match it; run `HYBID-Discovery.ps1`. Implement: Add and verify the public domain in Entra; add the matching UPN suffix in AD and update user UPNs.

G8. Network access to Microsoft cloud endpoints

Description: Outbound HTTPS (443) from the Connect host to Entra ID, plus required Microsoft 365 service URLs. Why: Synchronization, authentication-agent traffic, and tokens depend on these endpoints. Verify: From the Connect host, reach `https://login.microsoftonline.com` and the Microsoft 365 published URL/IP ranges. Implement: Allow the Microsoft 365 / Entra service URLs and IP ranges through the proxy/firewall.

The deployment model (all solutions): Assess -> Configure -> Pilot -> Validate -> Expand.

GCC High Parity Notes — Zero Trust Conditional Access Baseline & Rollout

This document is specific to the **Government (GCC High)** edition of this solution. It records the US Government national-cloud endpoints this Conditional Access baseline uses, the feature-parity considerations that differ from commercial Entra, and the compliance/data-residency context — framed around the federal Zero Trust mandate — that motivates GCC High. It does **not** assert availability or make

an authorization decision: every version/preview/plan fact must be **verified against current Microsoft Government documentation** for your specific cloud (GCC High vs DoD/IL5), and accreditation determinations belong to your ISSO/compliance function.

National cloud endpoints

Purpose	Commercial (do **not** use here)	GCC High / Azure Government (use this)
Entra / Azure AD admin	`entra.microsoft.com` / `portal.azure.com`	`portal.azure.us` → **Microsoft Entra ID** (Azure Government) — *verify the current GCC High Entra admin-center URL for your tenant*
Microsoft 365 admin center	`admin.microsoft.com`	`portal.office365.us` (GCC High) — *verify current URL*
Sign-in / token (Entra)	`login.microsoftonline.com`	`login.microsoftonline.us`
Microsoft Graph	`graph.microsoft.com`	`graph.microsoft.us` (GCC High) — DoD/IL5 uses `dod-graph.microsoft.us`; **verify your cloud**
Graph PowerShell SDK cloud	`Connect-MgGraph` (Global)	`Connect-MgGraph -Environment USGov` (DoD/IL5: `-Environment USGovDoD`)

All five scripts (`ENTZTCAG-Discovery.ps1`, `ENTZTCAG-Validate.ps1`, `ENTZTCAG-Report.ps1`, `ENTZTCAG-Set-Baseline.ps1`, `ENTZTCAG-Set-ScopeTargeting.ps1`) connect with `Connect-MgGraph -Environment USGov`. `ENTZTCAG-Set-ScopeTargeting.ps1` builds group-member `@odata.id` bind references from the connected environment's Graph endpoint (so it uses `graph.microsoft.us` in GCC High and `dod-graph.microsoft.us` in DoD automatically). For a DoD/IL5 tenant, change the `-Environment` value to `USGovDoD` in each script's `Connect-MgGraph` line.

Feature-parity considerations

GCC High and DoD frequently **lag commercial Entra** or differ in availability. For this Conditional Access baseline, treat each of the following as **"verify against current Microsoft Government documentation"** before you rely on it — do not assume parity, and do not invent availability:

- **Risk-based Conditional Access —** `CA004` **(sign-in risk) and** `CA005` **(user risk)** — these depend on

Microsoft Entra ID P2 / Identity Protection. Identity Protection availability, risk-signal fidelity, and specific risk conditions **may lag or differ in GCC High/DoD** even where a P2 (Government) SKU is licensed. **Verify** before designing around them; if unavailable, compensate with the non-risk controls (`CA001` MFA + `CA003` compliant/hybrid device everywhere) and note the gap.

- **Authentication strengths (**`CA002` **phishing-resistant MFA)** — the built-in authentication-strength

definitions and the exact strength id can differ in the sovereign cloud. **Verify** the `Phishing-resistant` MFA strength exists and confirm its id in `ENTZTCAG-Set-Baseline.ps1` matches your tenant.

(Phishing-resistant MFA is the M-22-09 core requirement — prioritize it.)

- **Device controls (**`CA003` **compliant / hybrid Entra-joined device)** — depend on **Intune** device compliance and/or Entra hybrid join being available and configured in your Gov tenant. **Verify** the device signal is present before enforcing.
- **Continuous access evaluation, token protection, and newer session controls** — these and other preview or recently-GA capabilities are commonly **delayed or absent** in GCC High/DoD. Do not depend on a preview control for a Gov deployment. **Verify.**
- **What-If and Insights & reporting (report-only workbook)** — supported in Azure Government; confirm the Log Analytics workspace backing "Insights and reporting" is within your accreditation boundary. **Verify.**
- **Workload-identity Conditional Access** (for service accounts) — licensing and availability differ; **verify** before planning to govern workload identities with dedicated CA rather than exclusions.

The **report-only-first, break-glass-excluded, wave-based** rollout method is identical to commercial — no parity concern there. It is the *feature availability* behind individual policies that must be verified for the sovereign cloud.

Compliance & data-residency context (why GCC High — and the Zero Trust mandate)

GCC High exists to keep regulated US Government and defense-industrial-base workloads inside a US-sovereign, US-persons-operated boundary. This Conditional Access baseline is how the federal Zero Trust mandate is operationalized at the identity plane. Context provided as background, not as an authorization:

- **OMB M-22-09 — "Moving the U.S. Government Toward Zero Trust Cybersecurity Principles"** — directs federal agencies to a Zero Trust architecture and specifically requires **phishing-resistant MFA** for staff, contractors, and partners, aligned to the **CISA Zero Trust Maturity Model** and **NIST SP 800-207**. The baseline's `CA001` (MFA), `CA002` (phishing-resistant MFA for admins), and `CA007` (block legacy auth) are direct implementations of these requirements.
- **CMMC 2.0 / NIST SP 800-171** — DIB contractors handling CUI face parallel access-control and MFA expectations (AC and IA control families). This baseline supports, but does not by itself constitute, a CMMC assessment.
- **FedRAMP High** — GCC High is designed to support FedRAMP High workloads; confirm the current authorization status and boundary for Entra Conditional Access / Identity Protection in your tenant.
- **DoD Impact Levels (IL4 / IL5)** — DoD workloads map to IL4/IL5 in GCC High-DoD; whether this deployment is in scope and at which impact level is your **ISSO/compliance determination**.
- **ITAR / EAR data-residency and US-persons handling** — GCC High provides US-only data residency and

screened US-persons operations required for ITAR/EAR-controlled technical data; confirm your data-handling obligations with your compliance/legal function.

Boundary determinations — the accreditation boundary, applicable impact level, which apps are "sensitive," which users are "privileged," how strict guest access must be, and whether a residual risk or exclusion is acceptable — are the **customer's ISSO, compliance, legal, and security functions'** decisions. This solution delivers the Zero Trust access controls, the report-only evidence, and the rollout method — not the authorization.

DoD (IL5) note

DoD tenants (GCC High-DoD / IL5) differ from GCC High in specific endpoints and availability:

- **Microsoft Graph host is** `dod-graph.microsoft.us` (not `graph.microsoft.us`), and the Graph

PowerShell environment is `Connect-MgGraph -Environment USGovDoD`. Change the `-Environment` value in each script's `Connect-MgGraph` line for a DoD tenant; `ENTZTCAG-Set-ScopeTargeting.ps1` then resolves the DoD Graph host for bind references automatically.

- **Feature availability can lag GCC High further at IL5** — Identity Protection / risk-based CA,

authentication strengths, and preview session controls in particular. **Verify each against current Microsoft Government documentation for the DoD cloud** before relying on it.

3. Implementation Guide — Zero Trust Architecture: Conditional Access Baseline & Rollout

Follow these steps in order. Most steps are in the **GCC High Microsoft Entra admin center** — the Azure Government portal (`https://portal.azure.us` → **Microsoft Entra ID**); *verify the current GCC High Entra admin-center URL for your tenant*. Sign-in is via `login.microsoftonline.us`. Discovery, reporting, validation, and the safe baseline creation use the included scripts, which connect to the US Gov cloud (`Connect-MgGraph -Environment USGov`).

> ***National cloud (GCC High):*** *all portal navigation paths below (`Identity -> Protection -> Conditional Access`, `What If`, `Insights and reporting`) are the same, but reached through the Azure Government portal.* ***Feature parity can lag commercial*** *— risk-based CA (`CA004`/`CA005`, Entra ID P2 / Identity Protection), authentication strengths, and device controls* ***may be delayed, unavailable, or different*** *in GCC High/DoD.* ***Verify each against current Microsoft Government documentation*** *for your cloud (GCC High vs DoD/IL5) and omit/substitute where not available, noting the gap. DoD/IL5 Graph host is `dod-graph.microsoft.us` and the SDK environment is `USGovDoD`.*
>
> *Model: define personas as groups, build a numbered baseline of policies* ***all in report-only*** *with break-glass excluded, validate every policy with report-only insights and the What-If tool on a pilot ring, then enforce wave by wave with rollback ready. No policy is ever created straight into enforcement, and break-glass is excluded from every policy from the first save.*

Object naming convention (used everywhere below and in the scripts): `<Purpose> - <Scope> - <Stage>` **for groups, and** `CA0nn <Purpose> - <Persona> - <Stage>` **for policies.** Create these once and reuse the exact names in testing, troubleshooting, and scripts:

Object	Name
Break-glass exclusion group	`CA Exclusion - Break-Glass - Steady`
Admins persona	`CA Persona - Admins - Steady`
Internal staff persona	`CA Persona - Internals - Steady`
External / guest persona	`CA Persona - Externals-Guests - Steady`
Service accounts persona	`CA Persona - Service-Accounts - Steady`
Pilot ring	`CA Pilot Ring - Pilot - Pilot`

Baseline policies (each created - `Report-Only`, later renamed - `Enforce`):

#	Policy	Persona	Control	License
CA001	`CA001 Require MFA - Internals - Report-Only`	Internals	Require MFA	P1
CA002	`CA002 Require Phishing-Resistant MFA - Admins - Report-Only`	Admins	Auth strength: phishing-resistant	P1
CA003	`CA003 Require Compliant or Hybrid Device - Internals - Report-Only`	Internals	Require compliant OR hybrid device	P1 + Intune/hybrid
CA004	`CA004 Sign-in Risk MFA - Internals - Report-Only`	Internals	Require MFA on medium+ sign-in risk	**P2**
CA005	`CA005 User Risk Password Change - Internals - Report-Only`	Internals	Require secure password change on high user risk	**P2**
CA006	`CA006 App-Enforced Restrictions - Externals-Guests - Report-Only`	Guests	Session: app-enforced restrictions	P1
CA007	`CA007 Block Legacy Authentication - All Users - Report-Only`	All (break-glass excluded)	Block	P1

#	Policy	Persona	Control	License
CA008	`CA008 Sign-in Frequency + No Persistent Browser - Admins - Report-Only`	Admins	Session controls	P1

*`CA004`/`CA005` require Entra ID P2; `CA003` requires Intune compliance or hybrid join. *Verify availability in your tenant* and omit/substitute where you are not licensed, noting the gap.*

Step 1 — Create the persona, exclusion, and pilot groups

1. Entra -> `Identity -> Groups -> All groups -> New group` -> Security -> create

`CA Exclusion - Break-Glass - Steady` and add the two break-glass accounts.

1. Create the persona groups `CA Persona - Admins - Steady`, `CA Persona - Internals - Steady`,

`CA Persona - Externals-Guests - Steady` (dynamic rule `user.userType -eq "Guest"` works well), `CA Persona - Service-Accounts - Steady`, and the `CA Pilot Ring - Pilot - Pilot`.

1. Or run `ENTZTCAG-Set-ScopeTargeting.ps1` to create and preview all groups before you commit.

Step 2 — Assess the current state (baseline)

1. Run `ENTZTCAG-Discovery.ps1`. It reports, read-only: existing CA policies and their states, which

policies exclude break-glass, detected legacy-authentication sign-ins, per-persona sign-in volume, and whether the tenant is P1 or P2 (so you know if the risk policies apply).

1. Save the output — it is your before picture and your legacy-auth migration list.

Step 3 — Build the baseline in report-only

1. For each policy in the table above: Entra -> `Identity -> Protection -> Conditional Access ->

Policies -> New policy, name it exactly (CA00n ... - Report-Only), set its assignments, conditions, and control per the table, and exclude CA Exclusion - Break-Glass - Steady under Users -> Exclude.

1. Set `Enable policy = Report-only` on every one. Create.

2. Or run `ENTZTCAG-Set-Baseline.ps1` (preview by default, `-WhatIf`) to create the whole numbered

baseline in report-only with the break-glass exclusion already applied. Review the preview, then re-run with `-WhatIf:$false`.

1. Key details per policy:

• `CA002`: `Grant -> Require authentication strength -> Phishing-resistant MFA` for the Admins

persona and All cloud apps.

- CA003: `Grant -> Require device to be marked compliant` OR `Require hybrid Entra joined device`

(select "Require one of the selected controls").

- CA004/CA005: under `Conditions -> Sign-in risk` / `User risk` (P2 only).
- CA006: `Session -> Use app enforced restrictions` for the Externals-Guests persona.
- CA007: `Conditions -> Client apps -> Exchange ActiveSync clients + Other clients`, `Grant ->

Block`, include All users, exclude break-glass (and any confirmed legacy exception, documented).

- CA008: `Session -> Sign-in frequency` + `Persistent browser session = Never` for Admins.

Step 4 — Validate every policy with What-If and report-only data

1. `Conditional Access -> What If`: for each persona pick a representative user, an app, and a device

state, and confirm the expected policies apply and the break-glass account has **no** policy applied. Fix scope/exclusions until What-If matches the design.

1. Let report-only run for a representative period (a few days of normal sign-ins). Review

`Conditional Access -> Insights and reporting` and `ENTZTCAG-Report.ps1`: confirm each policy *would* apply to the right persona, *would not* block break-glass or service accounts, and does not produce unexpected blocks.

Step 5 — Pilot enforcement on the pilot ring

1. Clone the persona policies you are ready to enforce (or add the `CA Pilot Ring - Pilot - Pilot`

include and set `Enable policy = On`) so only the pilot ring is enforced first.

1. Have pilot users exercise real sign-ins (managed device, unmanaged device, guest, admin). Complete

the Testing Guide. Watch for unexpected blocks; keep break-glass ready.

Step 6 — Enforce wave by wave

1. For each baseline policy that passed: flip `Enable policy = On` and rename the suffix `-

Report-Only `to -` Enforce`. Enforce in a sensible order — usually CA007 (block legacy) and CA001 (MFA) first for a wave, then device (CA003), then admin hardening (CA002, CA008), then risk (CA004/CA005`).

1. Roll persona by persona / wave by wave: enforce for `CA Pilot Ring - Pilot - Pilot`, then a first

wave of `CA Persona - Internals - Steady`, then the rest. Re-run `ENTZTCAG-Report.ps1` between waves to confirm no spike in blocks.

1. Keep each policy's report-only twin (or the ability to revert to report-only) until the wave is

proven.

Step 7 — Operate and review

1. Re-run `ENTZTCAG-Discovery.ps1` and `ENTZTCAG-Validate.ps1` on a cadence: confirm break-glass is

still excluded from every policy, no policy drifted to an overbroad scope, and no new legacy-auth or risky sign-ins are slipping through.

1. Review exclusions quarterly — every exclusion is a documented exception with an owner and an expiry

intent; remove the ones no longer needed.

Order of operations

```
Groups (personas + break-glass + pilot) -> assess -> build baseline in
report-only (break-glass excluded) -> validate with What-If + report-only data
-> pilot enforce on the ring -> enforce wave by wave -> operate/review
```

Rollback

• Any policy: set `Enable policy = Report-only` (or `Off`), or delete it — enforcement stops

immediately. Because every policy is validated in report-only first and break-glass is excluded everywhere, a bad policy never locks out admins.

• If a wave causes unexpected blocks: revert that policy to report-only, use `ENTZTCAG-Report.ps1` to

find the affected users/apps, fix the scope or exclusion, re-validate, then re-enforce.

• Emergency: sign in with a break-glass account (excluded from all policies) and set the offending

policy to report-only.

5. Testing Guide — Zero Trust Architecture: Conditional Access Baseline & Rollout

Run after the baseline is built in report-only (Implementation Step 3) and again before and after each enforce wave. Scripts are referenced by name; all reads are read-only.

Test 1 — Baseline exists and is report-only

Do: Run `ENTZTCAG-Discovery.ps1` (or `ENTZTCAG-Validate.ps1`). Expected: All baseline policies `CA001-CA008` (minus any you skipped for licensing) exist, each with `Enable policy = Report-only`, and each excludes `CA Exclusion - Break-Glass - Steady`.

Test 2 — Break-glass is excluded from every policy

Do: Run `ENTZTCAG-Validate.ps1 -BreakGlassUpn bg1@contoso.onmicrosoft.com,bg2@contoso.onmicrosoft.com`. Expected: Every policy reports the break-glass accounts as excluded — no policy applies to them. Any policy missing the exclusion is flagged in red.

Test 3 — What-If matches the persona design

Do: `Conditional Access -> What If` for one representative user per persona (admin, internal, guest) and for a break-glass account. Expected: Each persona sees the intended policies apply (admin -> `CA002`/`CA008`; internal -> `CA001`/`CA003`; guest -> `CA006`); the break-glass account has **no** policy applied.

Test 4 — Report-only impact is clean

Do: After a few days of report-only, review `Conditional Access -> Insights and reporting` and run `ENTZTCAG-Report.ps1`. Expected: Each policy "would apply" to the correct persona; no unexpected "would block" for legitimate users; service accounts are not caught by interactive policies.

Test 5 — MFA is required where enforced

Do: After enforcing `CA001` for a wave, have an internal pilot user sign in from a browser without a prior MFA session. Expected: The user is required to complete MFA; a user outside the enforced scope is not.

Test 6 — Phishing-resistant MFA required for admins

Do: After enforcing `CA002`, have a pilot admin attempt sign-in with only a phishable method. Expected: Access is blocked until they use a phishing-resistant method (FIDO2 / passkey); the admin succeeds with it.

Test 7 — Device control enforced

Do: After enforcing `CA003`, have an internal pilot user sign in from a non-compliant / non-hybrid device to a targeted app. Expected: Access is blocked (or remediation is required); the same user on a compliant/hybrid device is granted. *If `CA003` was skipped for licensing, mark N/A.*

Test 8 — Legacy authentication blocked

Do: After enforcing `CA007`, attempt a legacy-auth sign-in (for example a basic-auth mail client) as a scoped user. Expected: The legacy sign-in is blocked; modern-auth sign-ins for the same user succeed; break-glass and any documented legacy exception are unaffected.

Test 9 — Risk policies fire (P2 only)

Do: If licensed for P2 and `CA004`/`CA005` are enforced, simulate/observe a medium+ risk sign-in. Expected: `CA004` requires MFA on the risky sign-in; `CA005` requires a secure password change on high user risk. *Mark N/A if P1-only.*

Test 10 — Rollback works

Do: Set one enforced policy back to `Report-only`. Expected: Enforcement stops immediately; the policy still logs impact in report-only. Confirms the one-click rollback path.

Pass/fail gate

Gate	Requirement
Report-only pass	Tests 1-4 pass; every policy is report-only and excludes break-glass; report-only impact is clean
Pilot enforce pass	Tests 5-8 (and 9 if P2) pass for the pilot ring; Test 2 still passes; Test 10 confirms rollback
Wave expand pass	Tests 5-8 pass for each enforced wave with no spike in unexpected blocks (`ENTZTCAG-Report.ps1`); break-glass never blocked

6. Troubleshooting Guide — Zero Trust Architecture: Conditional Access Baseline & Rollout

Use `ENTZTCAG-Discovery.ps1` for the current policy inventory, `ENTZTCAG-Report.ps1` for report-only impact, `ENTZTCAG-Validate.ps1` for baseline state and break-glass exclusion, and the portal `Conditional Access -> What If` and `Insights and reporting` for per-user analysis.

A. Discovery / validation errors

Symptom	Cause	Remediation
`Connect-MgGraph` fails or scopes missing	SDK not installed, or read scopes not consented	`Install-Module Microsoft.Graph -Scope CurrentUser`; re-run and accept `Policy.Read.All`, `AuditLog.Read.All`, `Directory.Read.All`
No policies listed	Wrong tenant, or lacking CA read	Confirm the tenant; add `Security Reader` / `Conditional Access Administrator`
Sign-in log query empty	Needs Entra ID P1+ and `AuditLog.Read.All`	Confirm licensing and scope; widen `-LegacyLookbackDays` / `-LookbackDays`

B. A policy locked users out (or would have)

Symptom	Cause	Remediation
Users blocked right after enforce	The policy was enforced before its report-only data was clean	Set the policy back to `Report-only` immediately; run `ENTZTCAG-Report.ps1` to find the affected users/apps; fix scope/exclusion; re-validate; re-enforce
Admins at risk of lock-out	Break-glass not excluded	Add `CA Exclusion - Break-Glass - Steady` to the policy's `Users -> Exclude`; `ENTZTCAG-Validate.ps1` flags any policy missing it
Everyone caught by one policy	Policy targets All users with no exclusions	Re-scope to the correct persona group; the discovery/validate "All-users lock-out sweep" red-flags this
Fully locked out	—	Sign in with a break-glass account (excluded from all policies) and set the offending policy to `Report-only`

C. Break-glass exclusion keeps disappearing

• Confirm the break-glass accounts are members of `CA Exclusion - Break-Glass - Steady` and that the

group (not just the individual users) is excluded on every policy — a per-user exclusion is fragile. `ENTZTCAG-Validate.ps1` reports whether the exclusion is via group (preferred) or user.

D. Report-only shows nothing / What-If disagrees

• Report-only results only appear after real interactive sign-ins occur while the policy is in

report-only — allow a representative period. If `ENTZTCAG-Report.ps1` is empty, widen `-LookbackDays` or check `-PolicyNameLike` matches your policy prefix. What-If is a simulator and does not need sign-in history; if What-If and report-only disagree, trust What-If for scope logic and report-only for real-world impact, and reconcile the conditions.

E. Risk policies (CA004/CA005) not available or not firing

• Sign-in risk and user risk require **Entra ID P2** (Identity Protection). `ENTZTCAG-Discovery.ps1`

reports whether P2 is present; `ENTZTCAG-Set-Baseline.ps1` skips these automatically without P2. *If you are P1-only*, omit them and compensate with `CA001` (MFA) + `CA003` (compliant/hybrid device) everywhere, and note the gap. *Verify current availability in your tenant.* **In GCC High/DoD, Identity Protection / risk-based CA may lag or differ from commercial even where P2 is licensed — verify**

against current Microsoft Government documentation for your cloud before relying on it.

F. Device control (CA003) blocks compliant users

Symptom	Cause	Remediation
Compliant device still blocked	Device not actually reporting compliant / not hybrid-joined	Confirm in `Entra -> Devices`; check Intune compliance policy assignment and evaluation; the device must be registered and evaluated compliant
No device meets the control	Intune compliance or hybrid join not in place	Stand up device management first (adjacent solution), or use the control the tenant supports; *verify availability*

G. Legacy-auth block (CA007) broke an app

- A legacy/basic-auth app or mail client cannot do modern auth. Identify it from

`ENTZTCAG-Discovery.ps1` (legacy-auth section) and the sign-in logs, migrate it to modern auth, and only then block. If a legitimate legacy app must stay temporarily, add it as a **documented, time-boxed exception** — never a permanent silent carve-out.

H. Phishing-resistant strength (CA002) rejects everyone

- If admins have not yet registered a phishing-resistant method (FIDO2 / passkey), `CA002` will block

them once enforced. Register the method first (see the Passwordless & Passkey solution), confirm adoption, keep `CA002` in report-only until admins are enrolled, then enforce. Also verify the authentication-strength id in `ENTZTCAG-Set-Baseline.ps1` matches the built-in `Phishing-resistant MFA` strength in your tenant.

I. Diagnostics quick reference

```
# GCC High: -Environment USGov (DoD/IL5: -Environment USGovDoD). Without it, the SDK targets commercial Az
Connect-MgGraph -Environment USGov -Scopes 'Policy.Read.All','AuditLog.Read.All','Directory.Read.All' -NoW
# all policies with state and exclusions
(Invoke-MgGraphRequest -Method GET -Uri '/v1.0/identity/conditionalAccess/policies').value |
  Select-Object displayName, state, @{n='excludeGroups';e={$_.conditions.users.excludeGroups}}
# is the tenant P2?
((Invoke-MgGraphRequest -Method GET -Uri '/v1.0/subscribedSkus').value).servicePlans.servicePlanName |
  Where-Object { $_ -like 'AAD_PREMIUM*' } | Sort-Object -Unique
```

J. When to escalate

If a policy change locks out administrative access and a break-glass account cannot restore it, treat it as a Sev-1: use the second break-glass account, contact Microsoft support with the tenant ID, and follow your incident-response process. If you see a surge of risky sign-ins or an unexpected mass of report-only blocks that suggests an attack, keep the relevant policies enforced, engage Identity Protection (P2) and your security team, and do not disable the baseline to "make it work."

7. Best Practices — Zero Trust Architecture: Conditional Access Baseline & Rollout

- Report-only before enforce, always. Every policy is created in `Report-only`, validated with a few

days of real sign-in data and the What-If tool, and only then turned on. This single discipline is what makes a CA rollout safe.

- Exclude break-glass from every policy, no exceptions. Keep the two cloud-only emergency accounts in

`CA Exclusion - Break-Glass - Steady` and exclude that group from every policy — `ENTZTCAG-Validate.ps1` flags any policy that forgets. This is the anti-lockout guarantee.

- Design by persona, not one mega-policy. A numbered, persona-based baseline (admins, internals,

guests, service accounts) is legible, auditable, and rolled out group by group; a single "all users, all apps" policy is a lock-out waiting to happen.

- Number and name policies consistently. `CA0nn <Purpose> - <Persona> - <Stage>` makes the baseline

self-documenting and lets you reason about order and coverage at a glance.

- Keep exclusions minimal and documented. Every exclusion is a hole in the baseline — make each one a

named exception with an owner and a review date, not a convenience. Review them quarterly and remove what is no longer needed.

- Handle service accounts deliberately. Non-interactive accounts break under interactive MFA — scope

them out of interactive policies, document each one, and where licensed use workload-identity Conditional Access instead of a blanket exclusion.

- Block legacy authentication early, but migrate first. Legacy/basic auth cannot do MFA and undermines

the whole baseline — identify legacy-auth users/apps with `ENTZTCAG-Discovery.ps1`, migrate them to modern auth, then block legacy in waves so you do not break a line-of-business app.

- Require phishing-resistant MFA for admins. Generic MFA is still phishable; give the highest-value

accounts the `Phishing-resistant MFA` authentication strength plus tighter session controls (sign-in frequency, no persistent browser).

- Prefer device + MFA over risk-only where you are P1. Risk policies need Entra ID P2 — if you are

P1-only, compensate with require-compliant-device + MFA everywhere and note the gap; do not leave the persona uncovered.

- Roll out in waves with rollback ready. Enforce for the pilot ring, then a first wave, then the rest —

re-running `ENTZTCAG-Report.ps1` between waves. Keep every policy one click from report-only.

- Let the business own the classifications. Which apps are "sensitive," which users are "privileged,"

and how strict guest access must be are security/business decisions — the baseline enforces them; it does not decide them.

• Make review recurring. Re-run `ENTZTCAG-Discovery.ps1` and `ENTZTCAG-Validate.ps1` on a cadence so

policy drift, a lost break-glass exclusion, or new legacy-auth sign-ins are caught as they appear.

• Lead with the mandate (GCC High). Map the baseline to the federal Zero Trust drivers — **OMB M-22-09**

(phishing-resistant MFA, Zero Trust aligned to the CISA Maturity Model and NIST SP 800-207) and, for the DIB, **CMMC 2.0 / NIST SP 800-171**. `CA002` (phishing-resistant MFA for admins) and `CA007` (block legacy auth) are the highest-priority mandate controls; enforce them early regardless of P2 availability.

• Verify GCC High/DoD parity before you design. Connect scripts with `-Environment USGov` (DoD: `USGovDoD`);

use the Azure Government portal (`portal.azure.us`) / GCC High endpoints. **Risk-based CA (Entra ID P2 / Identity Protection), authentication strengths, and device controls may lag or differ in the sovereign cloud — verify each against current Microsoft Government documentation** (see `gcc-high-parity-notes.md`) and substitute non-risk controls where a feature is not yet available, noting the gap.

Where to go next

• **Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra** — deliver the phishing-resistant

method that `CA002` requires for admins.

• **Intune device compliance / hybrid join** — stand up the device signal that `CA003` depends on.

• **Identity Protection risk policies** and **Privileged Identity Management (PIM)** — pair the

baseline with risk-based access (P2) and just-in-time admin elevation for a complete Zero Trust identity story.

• **Enterprise App & Service Principal Governance** — govern the OAuth consent and workload-identity

surface that sits alongside interactive Conditional Access.

8. Deliverables Summary — Zero Trust Architecture: Conditional Access Baseline & Rollout

Documentation

Document	Purpose
Executive Summary	Business case and what is in the box
1. Solution Overview	The Conditional Access model — signals, conditions, grant/session controls, personas, report-only + What-If, break-glass, and licensing notes
2. Requirements Guide	Every solution-specific prerequisite with Verify / Implement-if-missing

Document	Purpose
Global Requirements (Entra ID Solutions)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered steps (persona/exclusion/pilot groups, assess, build the numbered baseline in report-only, validate with What-If + report-only data, pilot enforce, enforce wave by wave, operate/review)
5. Testing Guide	Validation procedures with pass/fail gates
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations + where to go next
GCC High Parity Notes	National-cloud endpoints, feature-parity considerations (P2/Identity Protection risk-based CA), and compliance/data-residency context (M-22-09, CMMC 2.0, FedRAMP High, DoD IL4/IL5) for the Government (GCC High) edition

PowerShell scripts

Script	What it does
`ENTZTCAG-Discovery.ps1`	Inventories existing CA policies and states, flags policies missing the break-glass exclusion, detects legacy-authentication sign-ins, and reports whether the tenant is P1 or P2 (read-only)
`ENTZTCAG-Validate.ps1`	Confirms the baseline policies exist, their report-only/enforce state, and that the break-glass accounts are excluded from every policy (read-only)
`ENTZTCAG-Report.ps1`	Report-only impact analysis from sign-in logs — which policies would have applied and which would have blocked, per persona, before you enforce (read-only)
`ENTZTCAG-Set-Baseline.ps1`	Creates the numbered baseline (`CA001-CA008`) in report-only, scoped to persona groups with break-glass excluded; `-WhatIf` by default (preview), gated apply
`ENTZTCAG-Set-ScopeTargeting.ps1`	Builds and previews the persona, break-glass exclusion, and pilot-ring groups

What the buyer receives

- This implementation guide as a Word document and PDF.
- All five PowerShell scripts in a single ZIP.
- A repeatable process: Assess -> Configure -> Pilot -> Validate -> Expand.

Delivered as a Complete Solution Package (PDF + Word + scripts).

Outcome

A production Zero Trust Conditional Access baseline enforcing least-privilege access — a clean, numbered, persona-based policy set validated in report-only and What-If, rolled out in waves with break-glass and one-click rollback, deployed without ever locking out the tenant.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

ENTZTCAG-Discovery.ps1

Purpose: Read-only assessment for a Conditional Access baseline: every existing CA policy and its state (enabled / disabled / report-only), which policies apply to "all users" and whether they exclude any accounts, detected legacy-authentication sign-ins from the audit log, per-persona sign-in volume, and whether the tenant has Entra ID P2 (so you know if the risk policies apply). This is your before baseline and your legacy-auth migration list. HOW TO RUN Install-Module Microsoft.Graph -Scope CurrentUser # once powershell -ExecutionPolicy Bypass -File .\ENTZTCAG-Discovery.ps1 Consents to Policy.Read.All, AuditLog.Read.All, Directory.Read.All (read-only). No changes. EXPECTED RESULTS A listing of CA policies with states and exclusions, a count of recent legacy-auth sign-ins, and the detected licensing tier. Nothing is modified. .NOTES White-label — Entra ID Solutions. Government (GCC High) edition: connects to the US Gov cloud via Connect-MgGraph -Environment USGov (DoD/IL5: USGovDoD, Graph host dod-graph.microsoft.us). Some CA capabilities (P2/Identity Protection risk conditions, auth strengths, device controls) may lag or differ in GCC High/DoD — verify against current Microsoft Government documentation. Read-only. > [CmdletBinding()] param([int]$LegacyLookbackDays = 7, [string]$CsvPath)

How to run: Install-Module Microsoft.Graph -Scope CurrentUser # once powershell -ExecutionPolicy Bypass -File .\ENTZTCAG-Discovery.ps1 Consents to Policy.Read.All, AuditLog.Read.All, Directory.Read.All (read-only). No changes. EXPECTED RESULTS A listing of CA policies with states and exclusions, a count of recent legacy-auth sign-ins, and the detected licensing tier. Nothing is modified. .NOTES White-label — Entra ID Solutions. Government (GCC High) edition: connects to the US Gov cloud via Connect-MgGraph -Environment USGov (DoD/IL5: USGovDoD, Graph host dod-graph.microsoft.us). Some CA capabilities (P2/Identity Protection risk conditions, auth strengths, device controls) may lag or differ in GCC High/DoD — verify against current Microsoft Government documentation. Read-only. > [CmdletBinding()] param([int]$LegacyLookbackDays = 7, [string]$CsvPath)

ENTZTCAG-Report.ps1

Purpose: Read-only analysis of what the report-only baseline WOULD have done. For recent sign-ins it reads the applied Conditional Access policy results (including report-only results) and summarizes, per policy: how many sign-ins it would have granted, would have required a control for (MFA/compliant device/etc.), or would have blocked. This is the evidence you review before moving a policy from report-only to enforce. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTZTCAG-Report.ps1 Optional: -LookbackDays 7 -PolicyNameLike 'CA00' -CsvPath .\ca-impact.csv Consents to AuditLog.Read.All, Policy.Read.All, Directory.Read.All (read-only). No changes. EXPECTED RESULTS Per-policy counts of would-grant / would-require / would-block from report-only results, so you can confirm impact is as intended (and break-glass/service accounts are not caught). Nothing is modified. .NOTES White-label — Entra ID Solutions. Government (GCC High) edition: connects to the US Gov cloud via Connect-MgGraph -Environment USGov (DoD/IL5: USGovDoD, Graph host dod-graph.microsoft.us). Some CA capabilities (P2/Identity Protection risk conditions, auth strengths, device controls) may lag or differ in GCC High/DoD — verify against current Microsoft Government documentation. Read-only. > [CmdletBinding()] param([int]$LookbackDays = 7, [string]$PolicyNameLike = 'CA0', [string]$CsvPath)

How to run: powershell -ExecutionPolicy Bypass -File .\ENTZTCAG-Report.ps1 Optional: -LookbackDays 7 -PolicyNameLike 'CA00' -CsvPath .\ca-impact.csv Consents to AuditLog.Read.All, Policy.Read.All,

Directory.Read.All (read-only). No changes. EXPECTED RESULTS Per-policy counts of would-grant / would-require / would-block from report-only results, so you can confirm impact is as intended (and break-glass/service accounts are not caught). Nothing is modified. .NOTES White-label — Entra ID Solutions. Government (GCC High) edition: connects to the US Gov cloud via Connect-MgGraph -Environment USGov (DoD/IL5: USGovDoD, Graph host dod-graph.microsoft.us). Some CA capabilities (P2/Identity Protection risk conditions, auth strengths, device controls) may lag or differ in GCC High/DoD — verify against current Microsoft Government documentation. Read-only. > [CmdletBinding()] param([int]$LookbackDays = 7, [string]$PolicyNameLike = 'CA0', [string]$CsvPath)

ENTZTCAG-Set-Baseline.ps1

Purpose: Creates the Zero Trust Conditional Access baseline policies (CA001-CA008) already scoped to the persona groups and with the break-glass exclusion group applied — every policy is created in REPORT-ONLY state (enabledForReportingButNotEnforced), never straight into enforcement. Defaults to -WhatIf, so a plain run only PREVIEWS the policies it would create and changes nothing. Enforcement is a deliberate, separate portal step done wave by wave after validation. Policies requiring Entra ID P2 (CA004 sign-in risk, CA005 user risk) are skipped automatically if the tenant is not P2, and CA003 device controls are noted as dependent on Intune/hybrid join. HOW TO RUN Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\ENTZTCAG-Set-Baseline.ps1 Apply after review (still report-only, not enforced): powershell -ExecutionPolicy Bypass -File .\ENTZTCAG-Set-Baseline.ps1 -WhatIf:$false Consents to Policy.ReadWrite.ConditionalAccess, Policy.Read.All, Group.Read.All, Directory.Read.All. EXPECTED RESULTS In preview: the baseline policies that WOULD be created (all report-only). When applied: the policies exist in report-only with persona scope and break-glass excluded. Reversible — delete or leave in report-only; nothing is enforced by this script. .NOTES White-label — Entra ID Solutions. Government (GCC High) edition: connects to the US Gov cloud via Connect-MgGraph -Environment USGov (DoD/IL5: USGovDoD, Graph host dod-graph.microsoft.us). Some CA capabilities (P2/Identity Protection risk conditions, auth strengths, device controls) may lag or differ in GCC High/DoD — verify against current Microsoft Government documentation. Write action — preview (-WhatIf) by default. Creates report-only ONLY. > [CmdletBinding(SupportsShouldProcess = $true, ConfirmImpact = 'High')] param([switch]$IncludeRiskPolicies # force-include CA004/CA005 even if P2 not auto-detected)

How to run: Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\ENTZTCAG-Set-Baseline.ps1 Apply after review (still report-only, not enforced): powershell -ExecutionPolicy Bypass -File .\ENTZTCAG-Set-Baseline.ps1 -WhatIf:$false Consents to Policy.ReadWrite.ConditionalAccess, Policy.Read.All, Group.Read.All, Directory.Read.All. EXPECTED RESULTS In preview: the baseline policies that WOULD be created (all report-only). When applied: the policies exist in report-only with persona scope and break-glass excluded. Reversible — delete or leave in report-only; nothing is enforced by this script. .NOTES White-label — Entra ID Solutions. Government (GCC High) edition: connects to the US Gov cloud via Connect-MgGraph -Environment USGov (DoD/IL5: USGovDoD, Graph host dod-graph.microsoft.us). Some CA capabilities (P2/Identity Protection risk conditions, auth strengths, device controls) may lag or differ in GCC High/DoD — verify against current Microsoft Government documentation. Write action — preview (-WhatIf) by default. Creates report-only ONLY. > [CmdletBinding(SupportsShouldProcess = $true, ConfirmImpact = 'High')] param([switch]$IncludeRiskPolicies # force-include CA004/CA005 even if P2 not auto-detected)

ENTZTCAG-Set-ScopeTargeting.ps1

Purpose: Creates (or previews) the security groups the CA baseline targets, following the naming convention <Purpose> - <Scope> - <Stage>: CA Exclusion - Break-Glass - Steady CA Persona - Admins -

Steady CA Persona - Internals - Steady CA Persona - Externals-Guests - Steady (dynamic: userType eq 'Guest') CA Persona - Service-Accounts - Steady CA Pilot Ring - Pilot - Pilot Defaults to -WhatIf (preview only). Optionally seeds break-glass members from -BreakGlassUpn. HOW TO RUN Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\ENTZTCAG-Set-ScopeTargeting.ps1 Create the groups: powershell -ExecutionPolicy Bypass -File .\ENTZTCAG-Set-ScopeTargeting.ps1 -WhatIf:$false -BreakGlassUpn bg1@contoso.onmicrosoft.com,bg2@contoso.onmicrosoft.com Consents to Group.ReadWrite.All, User.Read.All. EXPECTED RESULTS In preview: the groups that WOULD be created. When applied: the groups exist (guests group is dynamic). Idempotent — existing groups are reused, not duplicated. .NOTES White-label — Entra ID Solutions. Government (GCC High) edition: connects to the US Gov cloud via Connect-MgGraph -Environment USGov (DoD/IL5: USGovDoD, Graph host dod-graph.microsoft.us). Some CA capabilities (P2/Identity Protection risk conditions, auth strengths, device controls) may lag or differ in GCC High/DoD — verify against current Microsoft Government documentation. Write action — preview (-WhatIf) by default. > [CmdletBinding(SupportsShouldProcess = $true, ConfirmImpact = 'Medium')] param([string[]]$BreakGlassUpn)

How to run: Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\ENTZTCAG-Set-ScopeTargeting.ps1 Create the groups: powershell -ExecutionPolicy Bypass -File .\ENTZTCAG-Set-ScopeTargeting.ps1 -WhatIf:$false -BreakGlassUpn bg1@contoso.onmicrosoft.com,bg2@contoso.onmicrosoft.com Consents to Group.ReadWrite.All, User.Read.All. EXPECTED RESULTS In preview: the groups that WOULD be created. When applied: the groups exist (guests group is dynamic). Idempotent — existing groups are reused, not duplicated. .NOTES White-label — Entra ID Solutions. Government (GCC High) edition: connects to the US Gov cloud via Connect-MgGraph -Environment USGov (DoD/IL5: USGovDoD, Graph host dod-graph.microsoft.us). Some CA capabilities (P2/Identity Protection risk conditions, auth strengths, device controls) may lag or differ in GCC High/DoD — verify against current Microsoft Government documentation. Write action — preview (-WhatIf) by default. > [CmdletBinding(SupportsShouldProcess = $true, ConfirmImpact = 'Medium')] param([string[]]$BreakGlassUpn)

ENTZTCAG-Validate.ps1

Purpose: Read-only check of the Conditional Access baseline: (1) the expected numbered policies exist; (2) each is in the intended state (report-only during validation, enabled after enforce); and (3) every policy excludes the break-glass accounts. Prints PASS/WARN per policy and flags — in red — any policy that targets All users without excluding break-glass. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTZTCAG-Validate.ps1 -BreakGlassUpn bg1@contoso.onmicrosoft.com,bg2@contoso.onmicrosoft.com Optional: -ExpectReportOnly to require every CA0* policy to still be in report-only. Consents to Policy.Read.All, User.Read.All, Directory.Read.All (read-only). No changes. EXPECTED RESULTS PASS/WARN lines for policy presence, state, and break-glass exclusion. Nothing is modified. .NOTES White-label — Entra ID Solutions. Government (GCC High) edition: connects to the US Gov cloud via Connect-MgGraph -Environment USGov (DoD/IL5: USGovDoD, Graph host dod-graph.microsoft.us). Some CA capabilities (P2/Identity Protection risk conditions, auth strengths, device controls) may lag or differ in GCC High/DoD — verify against current Microsoft Government documentation. Read-only. > [CmdletBinding()] param([string[]]$BreakGlassUpn, [switch]$ExpectReportOnly)

How to run: powershell -ExecutionPolicy Bypass -File .\ENTZTCAG-Validate.ps1 -BreakGlassUpn bg1@contoso.onmicrosoft.com,bg2@contoso.onmicrosoft.com Optional: -ExpectReportOnly to require every CA0* policy to still be in report-only. Consents to Policy.Read.All, User.Read.All, Directory.Read.All (read-only). No changes. EXPECTED RESULTS PASS/WARN lines for policy presence, state, and

break-glass exclusion. Nothing is modified. .NOTES White-label — Entra ID Solutions. Government (GCC High) edition: connects to the US Gov cloud via Connect-MgGraph -Environment USGov (DoD/IL5: USGovDoD, Graph host dod-graph.microsoft.us). Some CA capabilities (P2/Identity Protection risk conditions, auth strengths, device controls) may lag or differ in GCC High/DoD — verify against current Microsoft Government documentation. Read-only. > [CmdletBinding()] param([string[]]$BreakGlassUpn, [switch]$ExpectReportOnly)